Sécurité des Réseaux Informatiques

Licence 3 - Informatique

2022

UPVD DALI

Plan

1. Vulnérabilité des réseaux
   - Dénis de service
   - IP spoofing
   - Sniffing
   - Vol de session
2. Pare-feux
   - Translation d'adresse
   - Filtrage

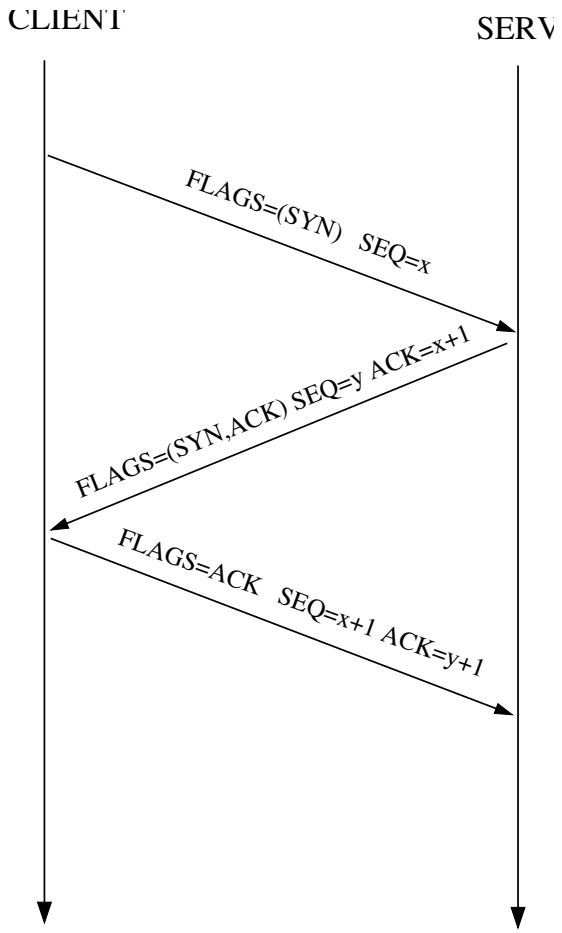
Plan

1. Vulnérabilité des réseaux
   - Dénis de service
   - IP spoofing
   - Sniffing
   - Vol de session
2. Pare-feux
   - Translation d'adresse
   - Filtrage

Le dénis de service (DOS) qu'est ce que c'est?

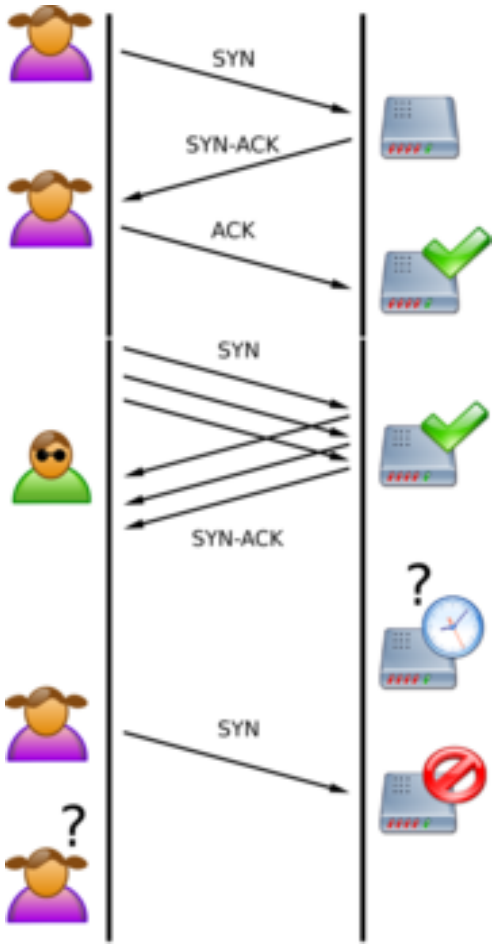
- Une attaque par déni de service consiste à empêcher un système informatique de fonctionner correctement.
- On inonde un serveur de requêtes, qui ne peut plus répondre à de nouvelle requête légitime.
- L'inondation peut monopoliser d'autre type de ressource: nombre de connexions simultanées ou la mémoire disponible.

SYN flooding - Rappel du mécanisme d'ouverture de connexion TCP



- Le client envoie un paquet SYN (le bit SYN $= 1$ le bit ACK $= 0$). Le numéro de séquence x est le numéro de séquence initial (ISN). Le numéro d'acquittement est zéro car l'ISN du serveur est inconnu.
- Le serveur répond par un paquet SYN-ACK (le bit SYN $= 1$ et le bit ACK $= 1$). Le numéro de séquence y est le numéro de séquence initial (ISN) choisit par le serveur, le numéro d'aquitement est $x + 1$.
- Le client répond au SYN-ACK par un segment ACK (SYN est à 0 et le bit ACK est à 1), le numéro de séquence est $x + 1$, le numéro d'ACK est $y + 1$.

SYN flooding



SYN flooding - description

Le SYN flooding est l'une des plus anciennes attaques de déni de service:

- Principe : L'attaque consomme toutes les ressources de la couche TCP d'un ordinateur.
- But : Lors de l'initialisation d'une connextion TCP, à la réception du paquet SYN, le serveur met cette connexion dans une file d'attente.
- Cela maintient la file d'attente constamment remplie, le serveur refuse alors systématiquement de nouvelle connexion.
- L'attaquant peut utiliser des adresses IP arbitraires vu qu'il n'est pas intéressé par réellement ouvrir connexion TCP.

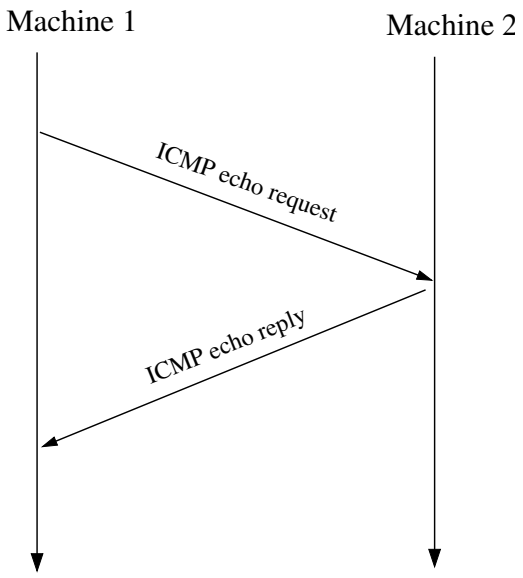
SYN flooding - parades

- Stratégie 1 : Les connexions en attente sont retirées de la file d'attente si l'ACK attendu n'arrive pas dans un délai raisonnable.

- Stratégie 2 : On en utilisant des SYN Cookies (Linux, FreeBSD) :
  - Le serveur ne maintient plus de file d'attente,
  - Les informations concernants la connexion sont encodées dans l'ISN, avec un mini-mécanisme de signature pour éviter des falsification.
  - A la réception de l'ACK le serveur récupère les informations des "vrai" clients et peut poursuivre la communication TCP en mode connecté.

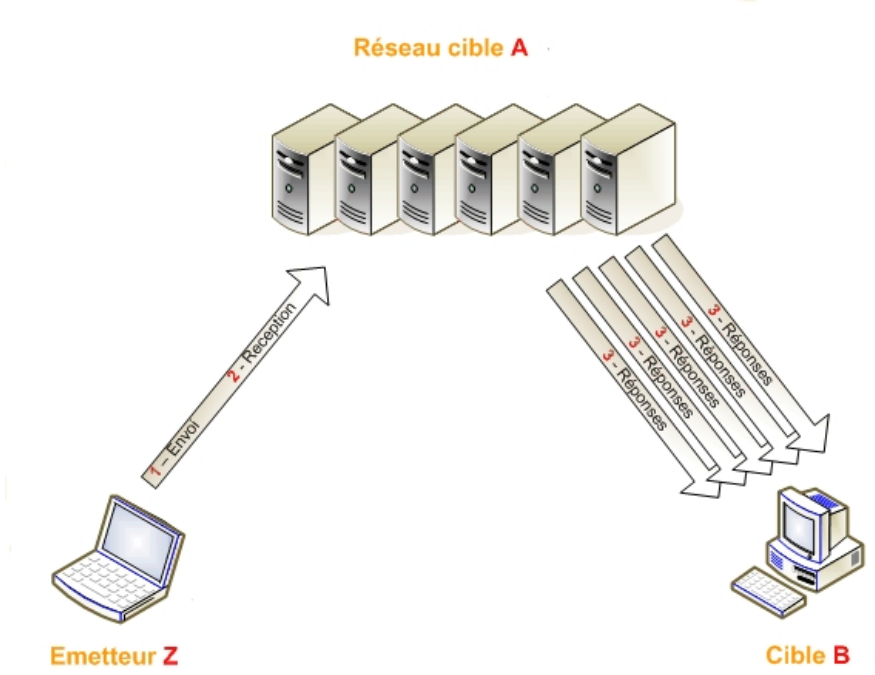
Attaque smurf

- L'attaque smurf consiste à noyer la victime dans un flux de de réponses ICMP.
- Rappel : ICMP est un protocole qui sert entre autre à vérifier qu'une machine est atteignable sur le réseau.
- Quand une machine reçoit un *ICMP echo request* elle envoie un paquet *ICMP echo reply* à l'adresse IP source indiquée dans le paquet



Attaque smurf

- Pour attaquer une cible avec des réponses ICMP, le pirate inscrit l'adresse cible comme adresse IP source dans l'en-tête IP du paquet ICMP de la requête.
- La destination de la requête enverra ainsi sa réponse à la cible.
- La cible ne saura d'ailleurs pas qui lui veut du mal.
- Pour amplifier son attaque le pirate peut envoyer sa requête à une adresse de diffusion réseau.



Attaque smurf

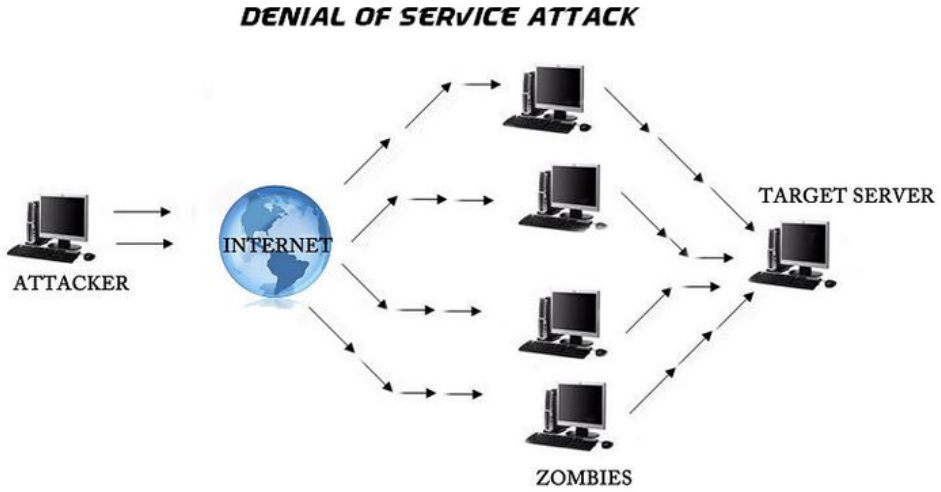
- Par exemple l'adresse par exemple on a fait un `ping -b 194.167.138.255` effectué à partir d'une machine dans le même sous-réseau.
- Les machines 194.167.138.* du sous-réseau ont répondu:

```
64 bytes from 194.167.138.168: icmp_req=7 ttl=64 time=0.337 ms
64 bytes from 192.168.138.150: icmp_req=7 ttl=254 time=0.356 ms (DUP!)
64 bytes from 194.167.138.177: icmp_req=7 ttl=255 time=0.369 ms (DUP!)
64 bytes from 194.167.138.180: icmp_req=7 ttl=64 time=0.373 ms (DUP!)
64 bytes from 194.167.138.112: icmp_req=7 ttl=64 time=0.377 ms (DUP!)
64 bytes from 194.167.138.240: icmp_req=7 ttl=64 time=0.380 ms (DUP!)
64 bytes from 194.167.138.27: icmp_req=7 ttl=64 time=0.383 ms (DUP!)
64 bytes from 192.168.138.1: icmp_req=7 ttl=255 time=0.740 ms (DUP!)
64 bytes from 194.167.138.219: icmp_req=7 ttl=64 time=0.761 ms (DUP!)
64 bytes from 194.167.138.163: icmp_req=7 ttl=64 time=0.765 ms (DUP!)
64 bytes from 194.167.138.181: icmp_req=7 ttl=64 time=0.768 ms (DUP!)
64 bytes from 194.167.138.161: icmp_req=7 ttl=64 time=0.772 ms (DUP!)
64 bytes from 194.167.138.199: icmp_req=7 ttl=64 time=0.775 ms (DUP!)
.
.
.
```

Autres attaques smurf et contre-mesure

- L'utilisation de paquets ICMP est un exemple classique d'une attaque par réflexion amplifiée.
- On peut aussi utiliser des segments UDP et qui génèrent des messages d'erreur plus longs que la requête du pirate.
- Contre-mesure : Pour limiter la multiplication de trafic à l'aide d'adresse de diffusion, beaucoup de routeur sont configurés pour ne pas relayer des paquet provenants de l'extérieur d'un sous-réseau.

Dénis de service distribués (DDoS)



- Un grand nombre de machines sous le controle du pirate attaque simultanément une cible.
- Des *backdoors* ou *porte dérobée* sont installées malicieusement sur les machines par le biais de failles de sécurité ou de virus.
- Ces machines infectées s'appellent bots (robots) ou zombies et ne communiquent pas directement avec le pirate mais par le biais d'un autre serveur (e.g. chat IRC ou encore twitter).

Dénis de service - un peu d'Histoire

- La première attaque DoS médiatisée a été un SYN flooding contre le fournisseur d'accès à Internet Panix dans le New Jersey en 1996.
- Cela s'est produit une semaine après la publication dans *Phrax* et *2600* du code source nécessaire pour effectuer un SYN flooding.

Dénis de service - un peu d'Histoire

L'an 2000 a vu apparaitre les premières attaques DDoS:

- Le 7 février le portail Yahoo fut inaccessible pendant plusieurs heures.
- Le 8 février Amazon, Buy.com, eBay et CNN étaient à leur tour victime d'une attaque.
- Le 16 février un pirate nommé Mafiaboy était suspecté d'avoir perpétré ces attaques: il fut arrêté le 15 avril, il s'agissait d'un canadien de 15 ans.
- Il avait compromis 75 ordinateurs différents grâce à une faille dans leurs serveurs FTP.

Plan

1. Vulnérabilité des réseaux
   - Dénis de service
   - IP spoofing
   - Sniffing
   - Vol de session
2. Pare-feux
   - Translation d'adresse
   - Filtrage

IP spoofing

Le spoofing d'IP consiste en la falsification d'adresse IP.

- Un routeur ou un pare-feu peut laisser des paquets qui proviennent de sites *amis*.
- Certaines applications offrent des privilèges aux connexions qui émanent de sous-réseaux connus.
- Par exemple `rsh` d'Unix peut permettre l'exécution de commande sans authentification préalable (s'assure que l'IP est dans la liste d'adresses IP amies).

Le Spoofing d'IP lors d'une session TCP

Il est particulièrement difficile de réussir une attaque par spoofing lors d'une session TCP:

- Si le pirate remplace son IP par une autre adresse, la cible enverra ses réponses à l'adresse falsifiée.
- C'est gênant car l'initialisation d'une session TCP passe par une séquence de SYN,SYN-ACK,ACK.
- Si le pirate ne peut pas répondre au SYN-ACK, il ne peut envoyer des données.

Dans certains cas on peut contourner ce problème.

TCP spoofing dans le même sous-réseau

Si l'attaquant est dans le même sous-réseau que l'adresse falsifiée:

- il pourra observer les réponses même si elles ne lui sont pas destinées.
- il verra l'ISN que le serveur propose dans le SYN-ACK.
- il pourra faire une réponse ACK valide, et envoyer des données avec une fausse adresse IP.

TCP spoofing à l'aveugle

- Si l'attaquant n'est ni dans le sous-réseau de la cible ni dans celui de la machine dont l'adresse IP est usurpée il ne n'observera pas le paquet SYN-ACK.
- Pour qu'il puisse répondre sans recevoir le SYN-ACK, il faut qu'il devine l'ISN contenu dans le SYN-ACK:
  - Si la méthode de génération de l'ISN est simple, quelques échantillons peuvent suffire pour générer les prochains ISN.
  - De vieilles versions de Windows et d'Unix utilisaient de simple incrément.

Plan

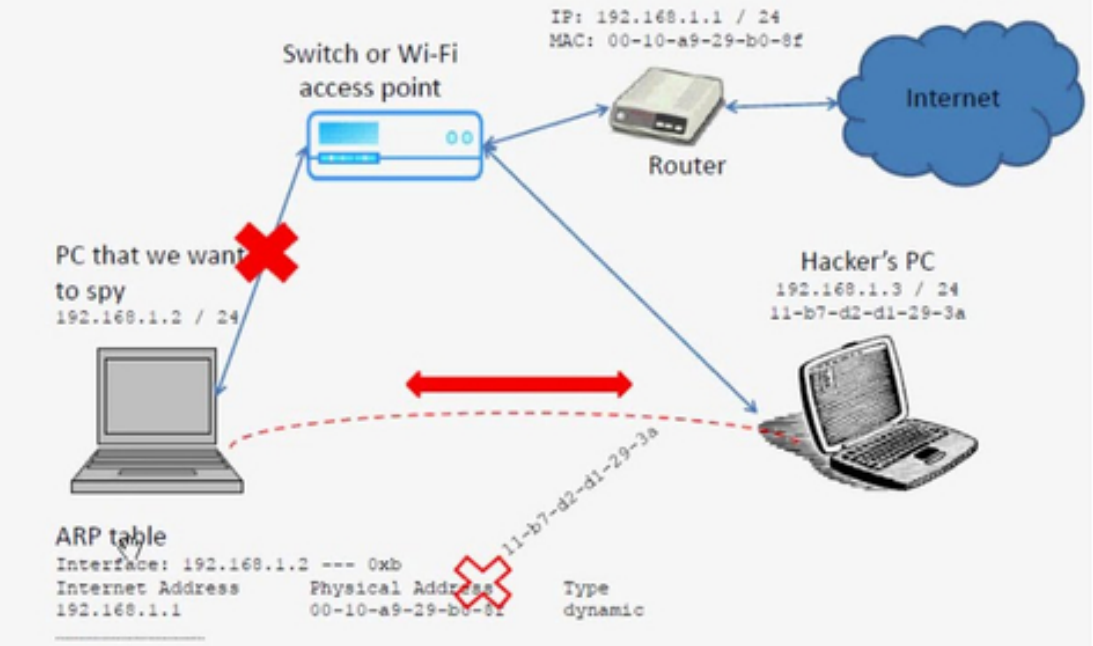
1. Vulnérabilité des réseaux
   - Dénis de service
   - IP spoofing
   - Sniffing
   - Vol de session
2. Pare-feux
   - Translation d'adresse
   - Filtrage

Sniffing

- Le sniffing consiste à capturer du trafic qui circule sur une partie du réseau.
- Le but du sniffing est d'exploiter le fait que beaucoup de méthode d'authentification transmettent les mots de passe en clair sur le réseau.
- C'est utilisé par les pirates pour étendre leurs attaques/réseaux de bots en prenant le contrôle de nouvelles machines.
  - Dans les réseaux locaux sans fils, c'est plus facile car le pirate a accès à toutes les données qui transitent.
  - Dans réseaux locaux câblés en général les machines sont connectés directement à des hubs et donc les trafics sont cloisonnés.

Sniffing avec de l'ARP spoofing

- Dans le cas des réseaux locaux cablés, le pirate peut utiliser une attaque de type ARP spoofing pour contourner le cloisonnement:
- L'ARP spoofing consiste à diffuser de fausses réponses ARP pour donner l'adresse Ethernet du pirate en lieu et place de celle de la cible.



Plan

1. Vulnérabilité des réseaux
   - Dénis de service
   - IP spoofing
   - Sniffing
   - Vol de session
2. Pare-feux
   - Translation d'adresse
   - Filtrage

Vol de session (session hijacking)

Vol de session :

- Le pirate attend qu'un utilisateur légitime se connecte à distance au système.
- Une fois que l'utilisateur s'est authentifié et que la connexion est établie, le pirate prend le contrôle de la connexion.

- La notion de session peut concerner la couche application ou la couche transport comme dans TCP.
- Un vol de session TCP peut provoquer des avalanches de paquet d'acquitement : cela perturbe l'ordre normal des numéros de séquence du client.

Vol de session HTTP

Session HTTP :

- Le protocole HTTP n'utilise pas vraiment la notion de session.
- En effet chaque requête pour une page web (page HTML, image, etc.) est traitée de manière indépendante.
- Les développeur web contourne ce problème en identifiant les utilisateurs grâce à des cookies et des données stockées sur une base de données.

Vol de session HTTP

Session HTTP :

- Le protocole HTTP n'utilise pas vraiment la notion de session.
- En effet chaque requête pour une page web (page HTML, image, etc.) est traitée de manière indépendante.
- Les développeur web contourne ce problème en identifiant les utilisateurs grâce à des cookies et des données stockées sur une base de données.

Vol de session :

- Si un pirate peut espionner les requêtes échangées entre un client et un serveur web:
  - il peut attendre que le client se soit authentifié puis envoyer une requête à sa place.
  - Ayant vu tous les échanges précédents le pirate connaît l'identifiant de connexion et peut donc le réutiliser.

Plan

1. Vulnérabilité des réseaux
   - Dénis de service
   - IP spoofing
   - Sniffing
   - Vol de session
2. Pare-feux
   - Translation d'adresse
   - Filtrage

Qu'est ce qu'un pare-feu

- Les pare-feux sont des composants d'un réseau utilisés chaque fois que l'on désire interconnecter deux réseaux possédant un niveau de sécurité différent.
- La fonction primitive d'un pare-feu est d'éviter la propagation d'un incendie.
- De façon analogue dans le contexte des réseaux, un pare-feu doit prévenir la propagation d'une attaque entre les différents réseaux qu'il relie.

Principes de base

- Maillon le plus faible : Un système sera aussi solide que son maillon le plus faible.
- Déni par défaut : Deux stratégies possibles:
  tout permettre sauf ce qui est explicitement interdit (dangereux) ou plus sur *tout interdire sauf ce qui est explicitement permis*.
- Participation des utilisateurs :
  - Un système de sécurité n'est efficace que si tous les utilisateurs adhèrent à ses principes.
  - Si le système met trop de contrainte aux utilisateurs, ils auront tendance à contourner ces règles, créant des failles de sécurité.

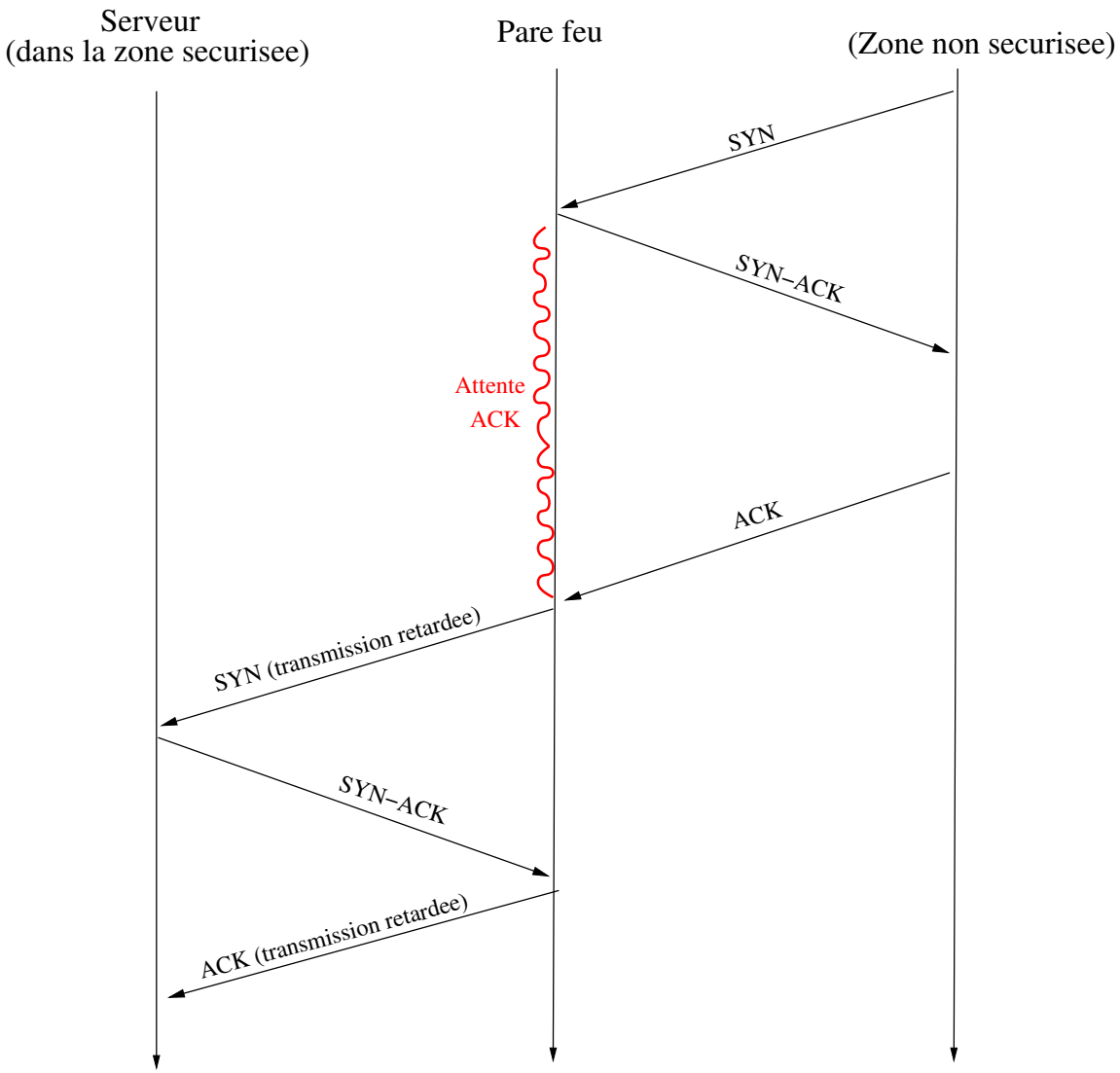
Types de pare-feu

- Logiciel ou matériel :
  - Logiciel : souvent utilisés dans les systèmes des PCs (zonealarm, etc).
  - Matériel dédié : moins sensible aux multiple failles des OS généralistes.

- Avec ou sans état :
  - Sans état : cela signifie que les paquets sont analysés indépendemment des uns des autres.
  - Avec mémoire : l'analyse se fait sur un flux de paquet (connexion TCP par exemple).

    Exemple : un paquet d'acquittement TCP ne peut être recu avant l'échange des paquets SYN et ACK.

Pare-feu avec état : SYN retardée



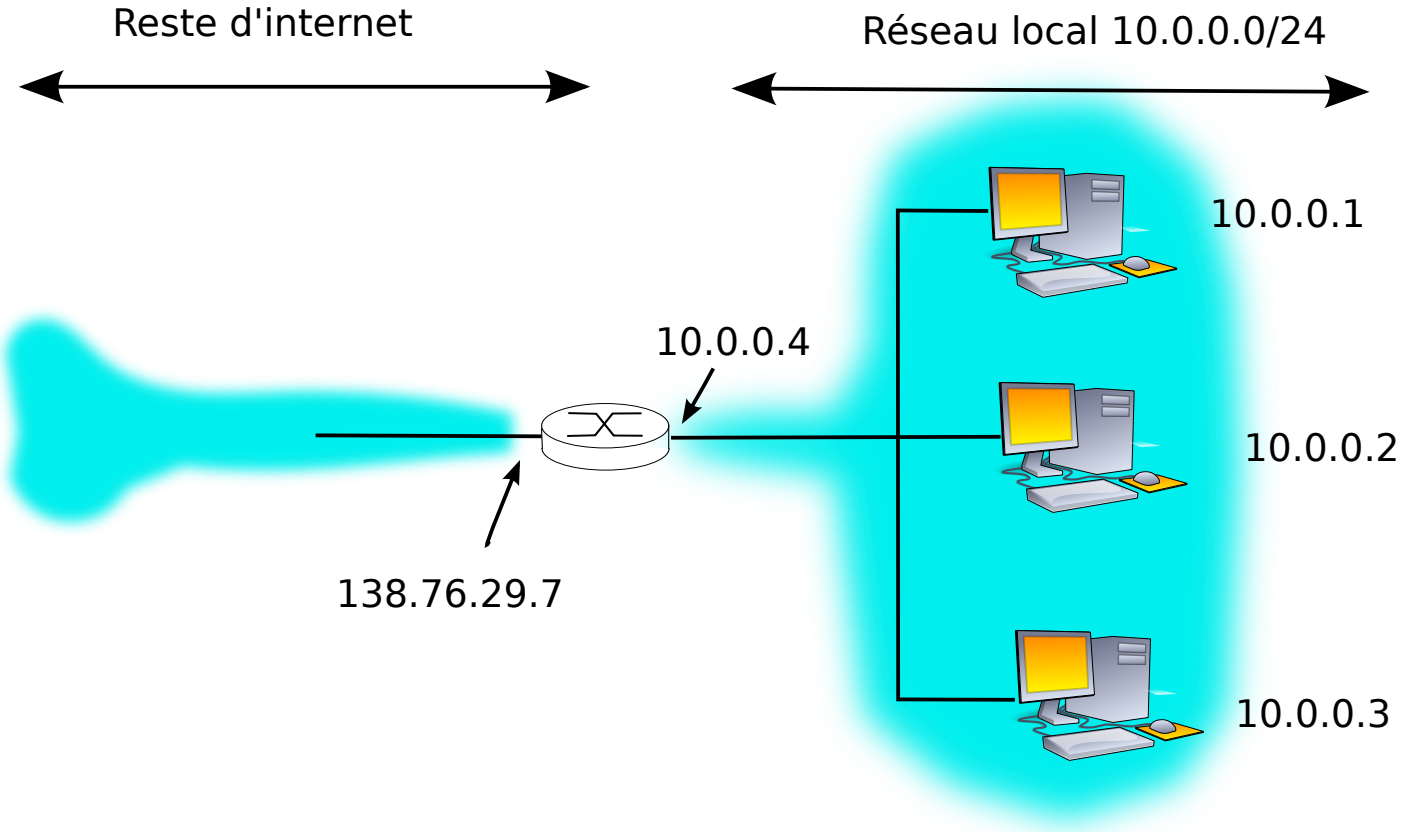
Ici le pare-feu mémorise temporairement les SYN entrant en attendant d'avoir la réponse ACK évitant un SYN flooding.

Plan

1 Vulnérabilité des réseaux
- Dénis de service
- IP spoofing
- Sniffing
- Vol de session

2 Pare-feux
- Translation d'adresse
- Filtrage

Translation d'adresse - Rappel

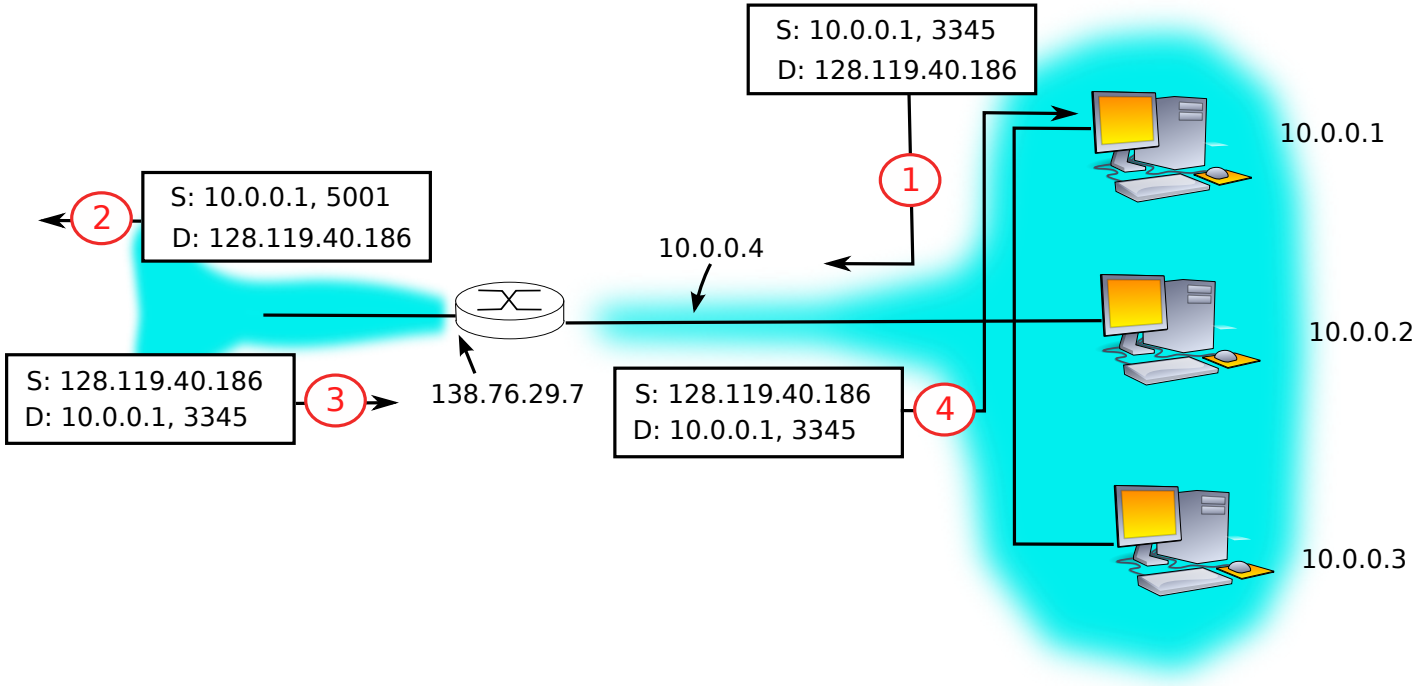


Tous les datagrammes quittant le réseau local ont la même adresse IP source: 138.76.29.7 mais différents numéros de port source

Les datagrammes avec une source ou une destination dans ce réseau ont 10.0.0.0/24 pour adresse réseau pour la source (ou la destination)

Translation d'adresse - Rappel

- Il permet à plusieurs machines d'accéder à Internet en utilisant une seule adresse externe.
- Le principe est d'identifier les adresse+port du sous réseau 10.0.0.0 par un numéro de port.
- Le routeur est alors chargé de faire les changements adresse/port par adresse publique/port associé lorsque les paquets sortent ou rentrent.



① L'hote 10.0.0.1 envoie un datagramme à 128.119.40.186, 80.
② le routeur NAT change adresse/port source 10.0.0.1, 3345 en 138.76.29.7, 5001.
③ La réponse arrive: adresse de destination est 138.76.29.7, 5001.
④ Le routeur change adresse/port de destination 138.76.29.7, 5001 en 10.0.0.1, 3345.

Table de translation	
addr. côté WAN	addr côté LAN
138.76.29.7, 5001	10.0.0.1, 3345
.....	.....

NAT dynamique et NAT statique

- Le NAT dynamique est le mode le plus utilisé (déjà vu dans le chapitre couche réseau): la table de translation se rempli et se vide au fur et a mesure que les connexions sont ouvertes ou fermées.
- La translation statique consiste à prédéfinir des relations entre adresse/port publique et adresse/port privé. Cela permet de donner accès au monde extérieur à des serveurs de la zone privée.

externe				interne			
source	port	dest.	port	source	port	dest.	port
10.0.0.1	25			172.1.3.2	25		
10.0.0.2	8080			172.1.3.2	80		

Plan

1 Vulnérabilité des réseaux
- Dénis de service
- IP spoofing
- Sniffing
- Vol de session

2 Pare-feux
- Translation d'adresse
- Filtrage

Filtrage : généralité

- Le filtrage consiste à autoriser ou bloquer du trafic à entrer ou sortir non d'une partie du réseau.
- Le filtrage consiste à applique certaines règles concernants les critères suivants:
  - Adresse IP source ou destination.
  - Protocole (TCP, UDP, ICMP, ...) et port.
  - Drapeaux et options : TCP SYN, ACK, ICMP.
- Exemple : le filtage d'adresse IP permet de contrer des attaques par spoofing.
- Exemple : le filtage sur les drapeaux SYN et ACK permet de contrer une attaque SYN.
- Exemple : le filtage sur ICMP peut autoriser des `echo-requests` que dans une direction (sortante).

Filtrage : généralité

- Un pare-feu est configuré via une liste de règles de filtrage.
- Pour chaque règle on doit spécifier les caractéristiques du paquet (adresses source et/ou destination, ports, drapeaux, ...) auxquelles la règle s'applique.
- Chaque règle contient aussi l'action à effectuée avec les paquets sélectionnés par exemple les laisser passer ou les détruire.
- Pour chaque paquet reçu le pare-feu parcourt la liste des règles jusqu'à ce qu'il en trouve une qui s'applique.
- L'ordre dans lequel ces règles sont lues est donc très important!.

Exemple 1 - règles de filtage : autorisation vers un serveur SMTP

	source	port	dest	port	protocole	action
1	*	*	10.0.0.1	25	TCP	permis
2	10.0.0.1	25	*	*	TCP	permis
3	10.0.0.1	*	*	25	TCP	permis
4	*	25	10.0.01	*	TCP	permis
5	*	*	*	*	*	interdit

- Les règles 1 et 2 laissent passer n'importe quel paquet entre une machine/port quelconque et le serveur SMTP (10.0.0.1, port 25).
- Les règles 3 et 4 autorisent le serveur de courrier électronique à se connecter au port 25 de n'importe quel autre serveur pour déposer du courrier.
- La dernière règle interdit toute autre type de connexion.

Exemple 1 - règles de filtage : autorisation vers un serveur SMTP

	source	port	dest	port	protocole	action
1	*	*	10.0.0.1	25	TCP	permis
2	10.0.0.1	25	*	*	TCP	permis
3	10.0.0.1	*	*	25	TCP	permis
4	*	25	10.0.01	*	TCP	permis
5	*	*	*	*	*	interdit

Problèmes : pare feu trop permissif

- Les règles 1 et 2 autorisent la connexion d'un client sur le port 25 du serveur SMTP à se connecter sur n'importe quel machine/port.
- Les règles 3 et 4 autorisent un client sur le port 25 de n'importe quel machine de se connecter sur n'importe quel port du serveur SMTP.

On peut corriger ces problemes en ajoutant des conditions sur les flags SYN et ACK.

Exemple 2 - règles de filtage : autorisation vers un serveur SMTP

	source	port	dest	port	protocole	ACK set?	action
1	*	*	10.0.0.1	25	TCP	*	permis
2	10.0.0.1	25	*	*	TCP	oui	permis
3	10.0.0.1	*	*	25	TCP	*	permis
4	*	25	10.0.01	*	TCP	oui	permis
5	*	*	*	*	*	*	interdit

- La modification dans la règle 2 interdit l'ouverture de connexion par *10.0.0.1 port 25* vers une autre machine.
- La modification dans la règle 4 interdit l'ouverture d'une connexion d'une machine quelconque (port 25) vers le serveur (port quelconque).

Exemple 2 - règles de filtage : autorisation vers un serveur SMTP

	source	port	dest	port	protocole	ACK set?	action
1	*	*	10.0.0.1	25	TCP	*	permis
2	10.0.0.1	25	*	*	TCP	oui	permis
3	10.0.0.1	*	*	25	TCP	*	permis
4	*	25	10.0.01	*	TCP	oui	permis
5	*	*	*	*	*	*	interdit

Problème persistant:

- Si un pirate forge des paquets avec les drapeaux appropriés, le pare-feu les laissera passer.
- Le pare feu n'ayant pas de mémoire il ne peut faire la distinction entre un paquet TCP forgé d'un paquet TCP authentique.
- C'est la limite des pare-feu sans mémoire !

Exemple 3 - autorisation vers un serveur SMTP - pare-feu avec mémoire

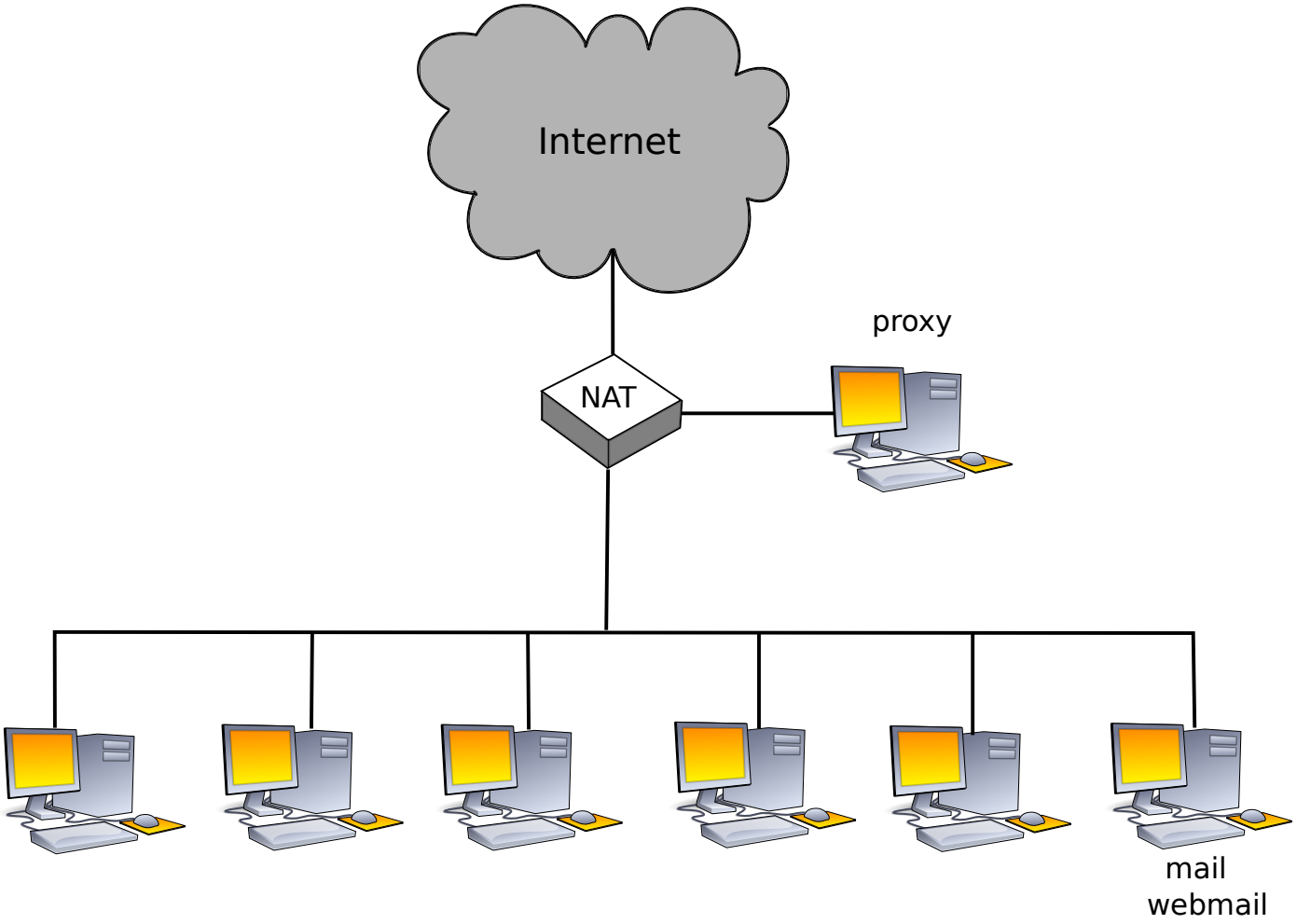
	source	port	dest	port	protocole	action
1	$*$	$*$	10.0.0.1	25	TCP	permis
2	10.0.0.1	$*$	$*$	25	TCP	permis
3	$*$	$*$	$*$	$*$	$*$	interdit

- Les pare-feu avec mémoire savent qu'un paquet SYN doit être suivi d'un paquet SYN-ACK.
- On peut donc spécifier le sens de la connexion (source = client initiateur de la connexion TCP, destinataire = serveur).
- La table de filtrage est plus simple !

Organisation des règles de filtrage

- Les règles sont parcourues séquentiellement.
- Si une règle a pour but d'interdire un service est précédée d'une règle l'autorisant cette règle n'a aucun effet.
- Pare-feu dans une DMZ :
  - Pour les serveurs web: connexions entrantes autorisées, connexions sortantes refusées.
  - Les machines internes ne devraient être autorisées à accéder qu'aux proxies.

Pare-feu avec zone démilitarizée



Règles de filtrage DMZ

	source	port	dest	port	protocole	action
1	$*$	$*$	dmz-web	80	TCP	permis
2	interne	$*$	proxy	80	TCP	permis
3	interne	$*$	$*$	$*$	$*$	interdit
4	$*$	$*$	$*$	$*$	$*$	interdit

On remarque que la première règle autorise toute les machines à se connecter au dmz-web.

Règles de filtrage DMZ

	source	port	dest	port	protocole	action
1	$*$	$*$	dmz-web	80	TCP	permis
2	interne	$*$	proxy	80	TCP	permis
3	interne	$*$	$*$	$*$	$*$	interdit
4	$*$	$*$	$*$	$*$	$*$	interdit

On remarque que la première règle autorise toute les machines à se connecter au dmz-web.

	source	port	dest	port	protocole	action
2	interne	$*$	proxy	80	TCP	permis
3	interne	$*$	$*$	$*$	$*$	interdit
1	$*$	$*$	dmz-web	80	TCP	permis
4	$*$	$*$	$*$	$*$	$*$	interdit

Ce problème est corrigé en intervertissant l'ordre des règles 1 et 2.

Organisation des règles

Une manière systématique de traiter les configurations complexes consiste à

- définir différents niveaux de sécurité pour chaque zone
- créer des règles en ordre décroissant de niveau de sécurité.

Pour chaque zone et chaque direction

- des règles sont créées pour autoriser le trafic désiré.
- suivies d'une règle interdisant tout le reste du trafic.

Références

- *Sécurité informatique - cours et exercices corrigés.* G. Avoine, P. Junod et Philippe Oechslin. 2eme ed. Vuibert.
- *Analyse structurée des réseaux.* J. Kurose et K. Ross. Pearson education.
- *Techniques de hacking.* J. Erickson. Pearson.